

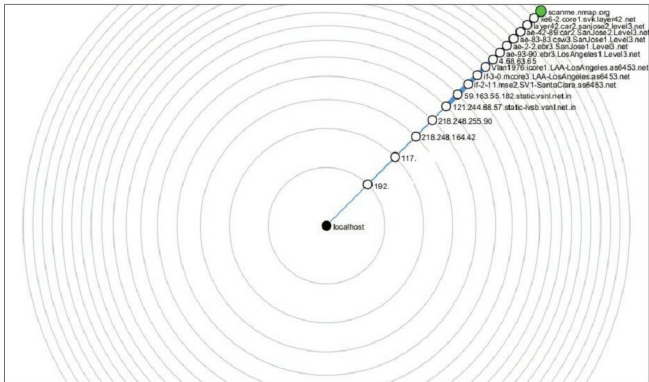


Figure 1: Sample Zenmap discovered hosts display

to make the target host see them as coming from the specified (-D) decoy hosts. The -sI and -D switches can't be combined, for obvious reasons.

Now, a word of caution: be careful not to cause an unintended Denial of Service (DoS) attack while using the -D option. To understand how this could happen, we need to know how a TCP handshake operates. TCP, being a connection-oriented protocol that guarantees delivery of packets, operates with a three-way handshake:

- The client initiates the communication by a SYN
- The server acknowledges with a SYN-ACK
- The client again sends an ACK, and now they can communicate.

If the -D switch is used, and there is a live host at the decoy IP address, then the SYN-ACK reaches the actual host at the decoy IP address, and not the host running the Nmap scan. Since the real host at the decoy address did not initiate the connection, it closes the connection by sending a TCP Reset (RST). There's no problem with this. However, a problem occurs if the decoy IP address is not active on the network—there is no RST sent to the scan target, which keeps the connection open. As Nmap continues to generate more and more requests to the target with the decoy IP as the source, the scan target has a growing list of open connections for which it maintains the 'connection initiated' state. This ends up consuming more and more resources on the target, and may cause a DoS to other, legitimate hosts and communications.

Other interesting command line options

Nmap's creators have considered many possibilities while designing it. One case in point is the -ttl option. To understand its use, let's once again go into some detail on the IP protocol. Packet headers contain a field called TTL (Time To Live). The TTL field is set by the machine from which the packet originates. Every machine that receives and relays it on the route towards its destination, decrements the TTL field value by some amount. If the TTL field value falls to zero before the packet arrives at its destination, then the packet is dropped, and an ICMP error is sent back to the sender. This mechanism is intended to prevent packets that could not be delivered to the target from remaining in circulation on the network and swamping the network resources.

Although TTL was originally meant to be a measure of time, as indicated by its name, in practice, its value is reduced by one on each hop (relaying of the packet) and not by some number of seconds. Thus, the value of the TTL field actually determines the maximum number of hops for which the packet can be relayed without being discarded. A typical default value for TTL on many operating systems is 128. However, Nmap's -ttl option lets you define a custom value for scan packets, which is a very useful feature. This includes, for example, ensuring that the packet is not relayed from your LAN onto the WAN/Internet. Fantastic, isn't it?

Some of the other important Nmap command line options that require an understanding of the TCP/IP protocol include: